Solution Design Cambridge Integration

Date	Nov 9, 2023
Design Contributor	
Design Producer	@Suresh Raghavan
Status (DRAFT | IN PROGRESS | IN REVIEW | APPROVED | ENDORSED | ON HOLD)	ENDORSED

	Approver (|)	Date Approved	Approval evidence
Analytics	N/A		
Data Governance	N/A		
Design Authority	@Srikanth Yelakaturu @Alex Crommelin (Unlicensed)	Jan 16, 2024	Reviewed and endorsed, concerns around Auth code generation has been raised. @Dinesh Kumar S (Unlicensed) to raise the risk in GRC portal (OneTrust) accepting this pattern. Endorsed at Solution Design Review Meeting. 
Design Lead	@Jayadev Devaraj @Senthilkumar Periyaswamy	Jan 9, 2024	
Idea Initiator	@Gemma Langdale		
Legal			
Privacy	@Jess Wilson		
Product Owner	@Gemma Langdale @Karthik Srinivasan		
Security	@Dinesh Kumar S (Unlicensed) @Chris Martyn	Jan 12, 2024	
Vendor Team			

Business Context

Opportunity/Problem Statement

This describes the business opportunity/problem statement.

The Cambridge Portal has test prep materials that could be useful for IELTS Test takers. So, the IELTS IDP mobile APP and the IELTS IDP Web India site would like to redirect the test takers to Cambridge, sharing minimal information about the users. So the IELTS Test takers could utilize the free and paid courses.

As a part of this integration,

- There is no need to enable login again in Cambridge. That is, an SSO mechanism is needed from IDP and Cambridge Portal.

The architectural design agreement between IDP and Cambridge is in the following document.

- IELTS Cambridge Integration - Architectural Design.docx

Business Objectives

This describes the business objective statement.

IELTS Test takers to utilize the free and paid courses that Cambridge offers, without signing in again.

Business Value

This describes the business value statement.

Customer Experience

Recovery Tier

This describes the Business Criticality of this asset which informs availability SLA’s, RTO, RPO and DR Test frequency.

Refer to [IDP Master Asset Register.xlsx (sharepoint.com)] for a list of Classified Applications

Business Criticality: Low business impact on organization but may be a key business function for a dept.

Options: Bronze

Business Process Flow

This describes the business process flow diagram

Business Functions

Capability	Function	Description
Test takers to access preparation material offered by Cambridge, that are free or paid, without re-login Test taker may purchase the paid courses.	To avoid re-login, Cambridge has to trust the user details that we share, along with the signature of that user details.	The proposal is accepted by Cambridge after checking with their technical team experts.

User Cohorts

User	Type	Business Area / External Group	Impact
test taker	End User	External	• Introduced CTA and concern to make use of Cambridge Learning Materials

Cambridge Tech team	Partner	External	• To allow the user sign-in, once they got user details of the test taker from IDP
			  ◦ IDP has to send the user details of the signed-in user along with the Client Certificate, signature, and timestamp to verify the user details they receive from IDP.
			• To allow the user to view the page, when redirected to the cambridge page, along with auth-token in url as query params.
			  ◦ IDP has to redirect the page with auth-token
			    ▪ Cambridge to show the web page with the user signed in.

Cloud Ops Support team	Cloud Ops	Internal	• To create new key-pair on demand or noticed as iff the certificate is identified as compromised.

Requirements

Functional Requirements

The epics and their features are to be met by this design.

⚠️ *<<This section is required and will be used to govern against* Principle 101: Requirements-Based Change *>>*

UI Wireframe

Refer to the Figma designs in the following link https://www.figma.com/file/oBKKGGBFfvoOTaFZA7hwcW/IELTS-App?type=design&node-id=9388-42390&mode=design&t=5rcmzggqpkgj9IS9-4 Connect your Figma account

Quality Attributes

<<Insert Non-functional requirements a.k.a NFR>>

Reporting Requirements

Any reports to be generated as a part of this business context...

Domain Events

<<List the events that this solution produces/depends>>

Event	Action	New, Modified or Existing
Event published or subscribed to by the components.	*Is this event to be published or consumed?*	*Is this an existing event, a modified event or a new one?*

Data Context

Data Domain Model

user_profile	
id	uuid
row_version	character varying
schema_version	integer
modified_by	character varying
modified_on	timestamp without time zone
created_by	character varying
created_on	timestamp without time zone
details	**jsonb**
sub	character varying
email_address	character varying
mobile_number	character varying
first_name	character varying
last_name	character varying
title	USER-DEFINED
legacy_ors_modified_on	timestamp without time zone
gender_id	uuid
nationality_id	uuid
nationality_other	character varying(100)
language_id	uuid
language_other	character varying(100)
date_of_birth	date
pii_data_masked	boolean
privacy_hold_enabled	boolean

- **consent:** Indicates the status of the consent acceptance of a user. If consent is accepted by the user, persist the timestamp, purpose, business partner (if any third-party access consent is accepted), and version
  - The “purpose” attribute is an enum with value, for now, is ['ACCESS_LEARNING_MATERIAL_CAMBRIDGE']
    - Note: later we can include: privacy_policy, cookie_policy, terms_and_conditions as per the business needs.
  - The “user_granted_permission” attribute maintains the consent is accepted by the user and granted permission for the “purpose”
  - The “lastAcceptanceDateTimeUTC” attribute maintains the time when the consent is accepted
  - The “version” attribute is defaulted to “1”, on every new release of content version, the version number has to be updated.
  - This would be an **attribute** in the JSON object of the “**details”** column.

An example object of the "details" column of user_profile table


```
{
  "user_address": {
    "city": "e91c2cfd-51ac-4ccf-8a27-b677a6c94394",
    "post_code": "f8b693ef-973a-4ff9-b287-7f3d277cb048",
    "country_id": "79e8a1fb-0b6a-7637-61bc-db11d1636f86",
    "territory_id": "daf35445-7bce-77a8-6b3d-f146e7caa14f",
    "street_address1": "ea78cd4a-19f6-47b7-a192-7b89e23db528",
    "street_address2": "725ae35a-fafb-4325-af63-34ae10fc81b1",
    "street_address3": "87f0175a-8175-462b-b9ee-92c98d51777f",
    "street_address4": "8334bab6-16e1-420a-acab-2f3c4f301c4c"
  },
  "user_identity": {
    "number": "5f12fc62-0ef7-4f93-b491-a6082ddacdc5",
```

```
    "s3_url": "aee3602c-89c9-4777-b95e-e08f5e81f258",
    "expiry_date": "2031-12-25",
    "issuing_authority": "de452a7b-7d36-42e5-9776-e9aa6ff77a58",
    "identification_type_id": "ca0274ab-4b8f-2ff3-a6e8-b8942b0f0d2f"
  },
  "consent":[{
    "purpose": "ACCESS_LEARNING_MATERIAL_CAMBRIDGE",
    "lastAcceptanceDateTimeUTC": "2024-01-12T07:18:55.672Z",
    "version": 1,
    "user_granted_permission": true
  }],
  "test_reason_id": "e388ddb7-9c29-ed03-e91e-042be58be60b",
  "years_of_study": "828d306f-4aad-43bc-8a1e-ddd28a4de0b2",
  "test_reason_other": "9f505c65-ca34-4258-b611-fe6b318edd6e",
  "education_level_id": "3f6c1068-87e0-b159-d7f7-96f6822d78a4",
  "occupation_level_id": "b84b2d3e-1bf4-fc79-d3d5-d6e0ceccc547",
  "occupation_sector_id": "10375967-22c8-74f3-d8cc-2fd66e21b32e",
  "country_applying_to_id": "28c6141c-c959-b0b8-cd23-4e2ef48f231c",
  "occupation_level_other": "e8d49e92-b39f-4cb9-975c-466f8299cffa",
  "study_contact_permission": true,
  "country_applying_to_other": "7268af42-5aac-4a0a-863a-d8b3fe9e310e",
  "currently_studying_english_at": "28b789fc-da32-4956-a24c-27217d09369e",
  "preparation_contact_permission": false,
  "push_notification_permission": true
}
```


Logical Data Model

<Insert logical data model>

Data Classification

(CONFIDENTIAL | SENSITIVE)

Confidential:

Sensitive:

Analytics Data

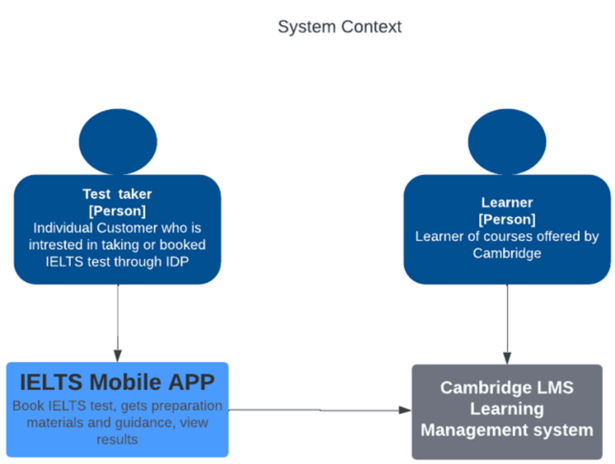
<Lists the specific requirements or dependencies from an analytics perspective.>

- [ ] @Murali Beela to confirm.

Technical Context

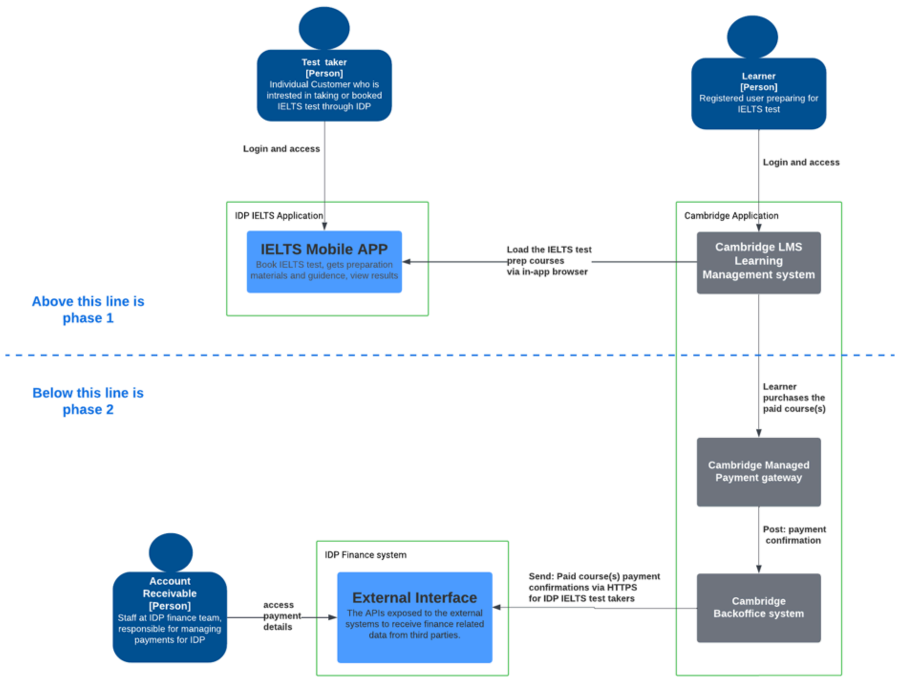
Context Diagram (C1)

<Insert Context diagram as per C4 modelling standards - Big picture diagrams showing how your system(s) behave with people>



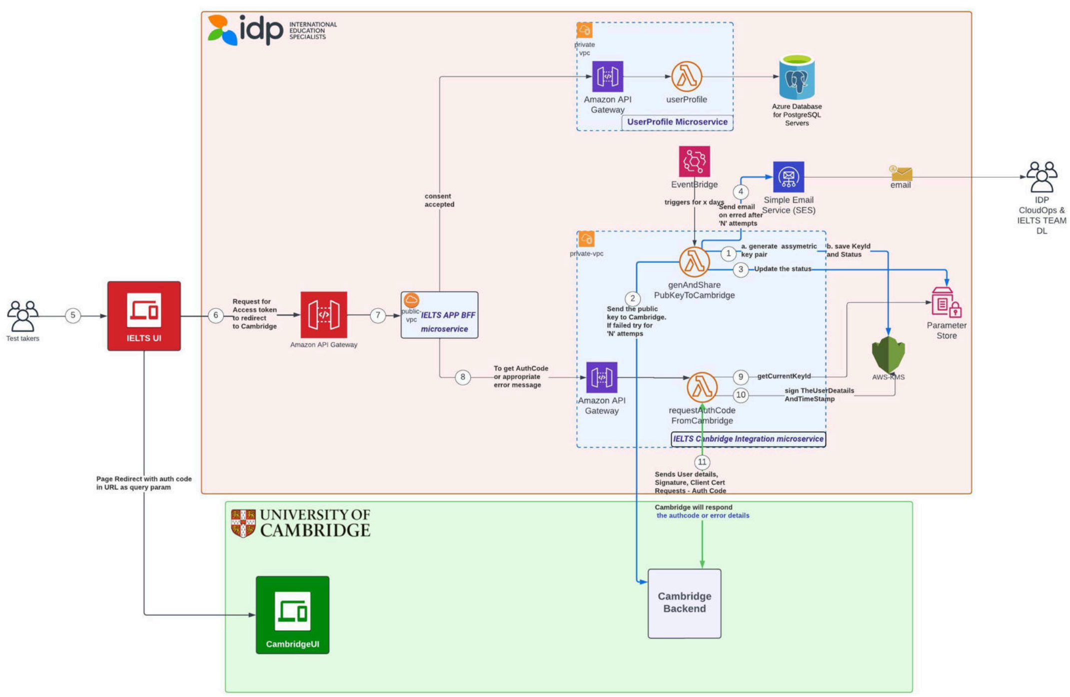
App Diagram (C2)

<Insert App diagram as per C4 modelling standards - High-level responsibilities of a system>



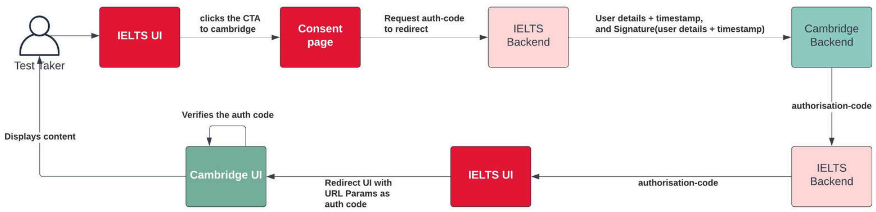
Technical Diagram (C3)

Technical flow diagram

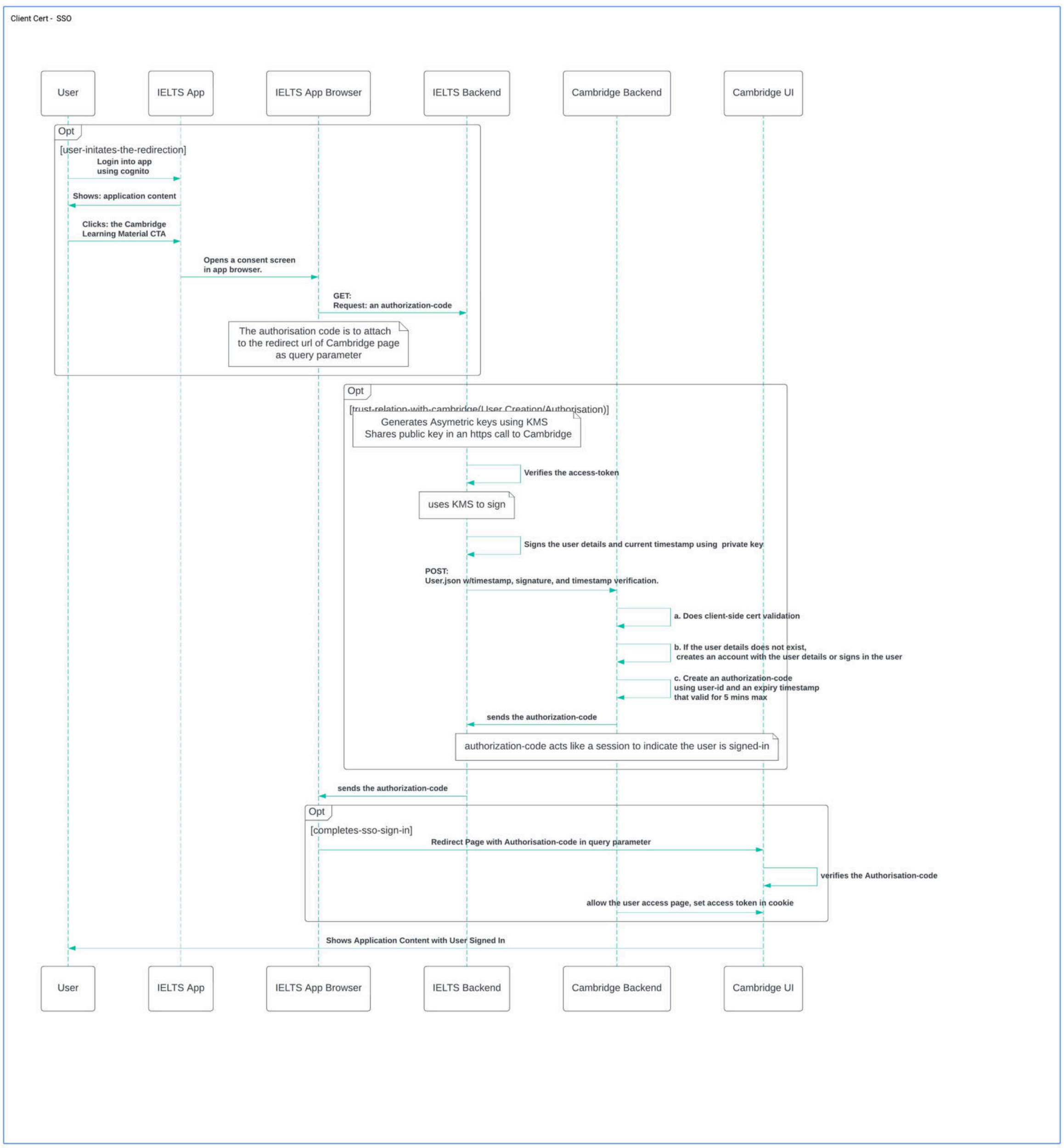


Detailed technical flow diagram for Client Certificate Authentication for SSO

High-level sequence diagram

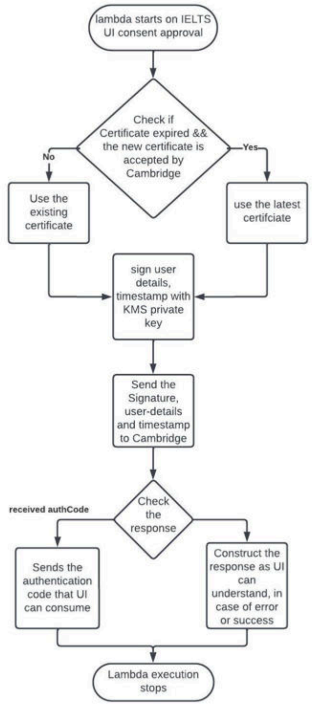


Detailed Sequence Diagram



Lambda 1: To get an authorization code from Cambridge

Name of the lambda:



{Env}-ielts-cambridge-connect-request-authcode-{version}

1. When the user clicks the CTA and approves the following consent page, this Lambda will be triggered.
2. The Lambda checks if the certificate expired. (Note the certificate details are stored in the parameter store.)
   a. if expired checks for the new certificate are accepted by Cambridge to use.,
   b. Otherwise use the existing certificate, till the certificate is expired.
3. Sign the User Details, timestamp by the Private-key.
4. Send the Signature, along with User Details and timestamp to Cambridge in a Secure HTTP call, requesting the authentication code
5. On receiving the response, return that to UI in the format that UI can understand.

IELTS APP BFF Open API spec

- Refer below at Solution Design Cambridge Integration | BFF Open API spec

IELTS CAMBRIDGE INTEGRATION MICROSERVICES Open API Spec

- Refer below at Solution Design Cambridge Integration | IELTS CAMBRIDGE INTEGRATION MICROSERVICES

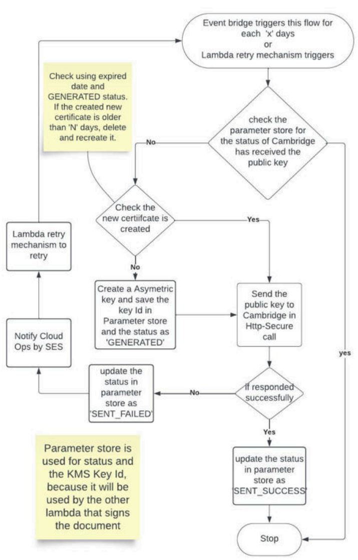
External API

Check the agreement document between IDP and Cambridge for API details at the following link.

- IELTS Cambridge Integration - Architectural Design.docx

> Note:
>
> The business partner Cambridge would like to restrict user access for a set of countries(refer: agreement document). It is possible to do this at UI. Also, engineering team has ensured, that during the Cognito session refresh, the contents are updated. That is when a person who installed mobile-app in INDIA where the Cambridge site is visible has moved to a location where the Cambridge link should not be visible will be happened in the UI, by this content update. So, NO need to add any check and restriction logic at the lambda.

Lambda 2: To generate a certificate and share that with Cambridge



Name of the lambda:

{Env}-ielts-cambridge-connect-generate-keypair-{version}

1. The lambda is executed by event-bridge in each 'x' days or by retry or by cloud ops on demand.
2. Lambda checks the parameter store for the status of the Cambridge-accepts-the-public-key shared with Cambridge successfully. Otherwise,
   - Check the new KeyId, if none exists, generate a new asymmetric key pair and save the KeyId in AWS-Parameter-store, and set the status as 'GENERATED'
   - Send the public key to Cambridge in the Http-Secure call
   - if got response status is 200, update the parameter store of Cambridge Public Key Acceptance as 'SENT_SUCCESS'. Otherwise, update the status as SENT_FAILED, and retry sending 3 times. After 3 consecutive failed attempts, notify Cloud Ops by SES.

External API

Check the agreement document between IDP and Cambridge for API details at the following link.

- IELTS Cambridge Integration - Architectural Design.docx

Parameter store values

1. KEY_ID
2. KEY_UTILITY_STATUS
    a. Statuses are: GENERATED, SENT_SUCCESS, SENT_FAILED

API Gateway

Name of the API-Gateway: {ENV}-ielts-cambridge-connect-{region}-apigateway-v1

Mandated Design Pattern(s):

<Insert the list of design patterns that should be used to build the technical architecture>

Event Source Map

A list of events that are ingested and published by this service.

- [ ] To discuss on the list of APIs to be included in the Solution Design template.

OpenAPI

IELTS APP BFF API

Click here to expand...

IELTS App

1.0.0 OAS 3.0

API Integration for IELTS App

User Profile

calls User Profile Microservice of IELTS

GET `/v1/user/preference/questions` Get user preference questions

POST `/v1/user/preference/manage` Update user preference answer

GET `/v1/user/preference` Get user preference answers

PATCH `/v1/userProfiles/{userProfileId}/consent` updating user profile for consent

RTBF

calls RTBF services of Servicenow Integration Services

DELETE `/v1/user/{userProfileId}/rtbf` User request for delete-my-account

PUT `/v1/user/{userProfileId}/rtbf/revoke` User cancels delete-my-account request

GET `/v1/user/{userProfileId}/rtbf/status` To get the user's delete-my-account status

Cambridge Connect

calls IELTS backend, to connect with Cambridge Application.

GET `/v1/cambridgeconnect/authcode` Get the authcode for the user to redirect to Cambridge

Schemas

user-preference-questions-response-200

user-preference-answers-response-200

onboarding-answer-response-200

Consent

ConsentAcceptanceRequest

ConsentTypes

response-200

response-202

response-401

response-404

response-500

response-ERR

RtbfRequestStatus-submit

RtbfRequestStatus-cancel

RtbfResponse-submit-200

RtbfResponse-cancel-200

cambridge-authcode-response-200

IELTS CAMBRIDGE INTEGRATION MICROSERVICES

Click here to expand...

IELTS Cambridge Integration Microservice 1.0.0 OAS 3.0

API for IELTS Cambridge Integration Microservice

Cambridge Connect calls IELTS backend, to connect with Cambridge Application.

GET `/v1/cambridgeconnect/authcode` Get the authcode for the user to redirect to Cambridge

Schemas

user-preference-questions-response-200

user-preference-answers-response-200

onboarding-answer-response-200

response-200

response-202

response-401

response-404

response-500

response-ERR

RtbfRequestStatus-submit

RtbfRequestStatus-cancel

RtbfResponse-submit-200

RtbfResponse-cancel-200

cambridge-authcode-response-200

USER PROFILE MICROSERVICES API

Click here to expand...

User Profile Microservice
v1.2 OAS 3.0

User Profile Microservice API Gateway

Servers

https://virtserver.swaggerhub.com/IdpEducation/ors

User Profile

- GET `/v1/userProfiles` get user profiles
- POST `/v1/userProfiles` inserting user profile
- PUT `/v1/userProfiles/{userProfileId}` updating user profile
- PATCH `/v1/userProfiles/{userProfileId}/consent` updating user profile for consent

RTBF

The API related to RTBF, which would be called by servicenow-integration-service.

- POST `/v1/userProfiles/rtbf/privacyHoldStatus`
  Get-by-post action, as the get action is dependent on email address which is PII, we pass that in the body. Returns the status of the Privacy Hold for the given user
- PATCH `/v1/userProfiles/rtbf/privacyHoldStatus` Enables (or) disables the Privacy Hold for the given user
- PUT `/v1/userProfiles/{userProfileId}/rtbf/anonymize` Anonymizes the PII data for the given User
- PATCH `/v1/userprofiles/stopMarketingActivities`
  This API is exposed to Stop marketing activities, if the user sends email to privacy officer for RTBF. Through IELTS-RTBF-IS, snow-shared service will trigger this API to stop marketing activities, for that email address.

Schemas

GetUserProfilesResponse

Gender

Language

Nationality

UserProfile

UserProfileRequestAddressDetails

UserProfileRequestIdentityDetails

UserProfileRequestMarketingDetails

UserProfileRequest

Consent

ConsentAcceptanceRequest

ConsentTypes

UserProfileTitle

GetByPostPrivacyHoldRequest

UpdatePrivacyHoldRequest

PrivacyHoldStatusResponse

AnonymizeRequest

UserProfileStopMAByEmailAddress

ValidationError

Error

ErrorResponse

ErrorSource

ErrorSourceType

ErrorType

uuid

Dependencies

<External or internal systems dependencies>

Security Context

User Access Use Cases

<<Identify the identity management to be used for each user cohort that will interact with the design. Informed by the Business Architecture.>>

User Cohort *(End users, customers, system administrators, business partners, etc)*	**User Type** *(Internal, External B2B, External B2C)*	**IDAM Solution** *Identify the solution component used to store and authenticate each user cohort*

Security Control Requirements

A Security Architect will work with the project to determine which of the below Security Controls are applicable to the solution.

Control *Refer to* (Deprecated) Solution Security Requirements *for more details*	**Applicable?** *(Y/N)*	**Met in the solution?** *(Y/N)*	**How Met** *Identify how the control is being met in the solution, or justify why a control cannot be implemented*
Identity & Access Management			
Identity Management (Internal users - employees, long term contractors, etc)	N		Not in scope for the solution design
Identity Management (External third parties / vendors - B2B)	Y	Y	Using Client Certificate Authentication
Identity Management (External customer end users - B2C)	N		Not in scope for the solution design
User Authentication & Single Sign-On	N		Not in scope for the solution design
Multi-Factor Authentication (MFA)	N		Not in scope for the solution design
Machine-to-Machine Authentication	Y	Y	Cambridge and IELTS are communicating through their backend servers. Cambridge Backend trusts IELTS using the digital signature sent by IELTS Backend.
Least Privilege Access Control	N		Not in scope for the solution design
Segregation of Duties	N		Not in scope for the solution design
Privileged Access Management	N		Not in scope for the solution design
Network Security			
Network Segmentation & Zoning	N		Not in scope for the solution design
Traffic Inspection and Flow Control	N		Not in scope for the solution design
Microsegmentation	N		Not in scope for the solution design
External Network Perimeter	N		Not in scope for the solution design
Web Application Firewall (WAF)	N		Not in scope for the solution design
API Gateway	Y	Y	The new resource is created for BFF call. New API Gateway is created for Cambridge Connect Microservice
Secure Web Gateway (SWG)	N		Not in scope for the solution design
Encryption & Key Management			
Encryption in Transit	Y	Y	The HTTPS call is used to communicate between IELTS and Cambridge.
Encryption at Rest	Y	Y	Only the user consent is persisted in the existing user_profile table in the existing postgres DB of user profile; By updating the existing record of details column.
Keys/secrets Management	Y	Y	The solution uses KMS to generate asymmetric keypair.
Approved Encryption Protocols	N		Not in scope for the solution design
Approved Encryption Algorithms	N		Not in scope for the solution design
Threat & Vulnerability Management			
Patching (Applications)	N		Not in scope for the solution design

Patching (Operating Systems)	N		Not in scope for the solution design
AV/EDR integration	N		Not in scope for the solution design
Vulnerability Management integration	N		Not in scope for the solution design
XDR integration	N		Not in scope for the solution design
File upload AV scanning	N		Not in scope for the solution design
Configuration Hardening (Security Baselines)	N		Not in scope for the solution design
Application Code Security Testing	N		Not in scope for the solution design
Platform vulnerability scanning	N		Not in scope for the solution design
Penetration testing	N		Not in scope for the solution design
Detection & Response			
Application audit logging	Y	Y	We strictly follow this as a standard practice
Platform security event logging	Y	Y	We strictly follow this as a standard practice
Log collection & SIEM forwarding	Y	Y	We strictly follow this as a standard practice

Third-Party Risk Assessment

<<If the project is introducing a new third party technology vendor/platform, engage Cyber Security to conduct a third party security risk assessment>>

Risk Impact Analysis

<Insert the Risk Impact Analysis>

Data Impact Assessment

What is the classification of the data the solution manages? Will it contain PII or sensitive data?

How is RTBF going to be managed?

What data retention period does the data have?

What data models are impacted by this solution?

Business Continuity Management

How does the solution address the DR category, Availability, RPO and RTO?

Operational Context

Support Model

<<How will the solution be supported?>>

Logging and Monitoring

<<Describe how the components will log application performance and security events to the enterprise log aggregation zone.>>

Cost Model

<<Describe the cost model for the operation of the solution, including whether it is up-front or ongoing user-based licences or consumption-based, how the costs increase or decrease with use>>

Architecture Principle Alignment

Reference all Architecture Principles Design Principles *and add commentary to explain how the solution aligns to or the justification for misalignment.*

Note: Principles are the guardrails for building solutions that are consistent and standardised - where feasible, practical and appropriate. It must be stressed that they are also not policy so if there is good reason (business and/or technical) for deviation then this can be discussed through the governance process and an informed decision made on whether to grant an exemption.

Legend	Meaning	Comments
✅	Fully Aligned	Briefly explain how the solution is fully aligned.
❌	Not Aligned	Provide justification as to why the solution is not aligned.
🟡	Partially Aligned	Briefly explain how the solution is partially aligned, with justification.
❓	More information needed	Explain what further clarification is required.
❎	Not Applicable	Briefly explain why this principle is not applicable.

Expand and complete the following Principles Alignment section:

Principles Alignment

Principle Domain	Principle	Aligned	Notes
Solution	• Principle 001: Primacy of Principles	✅	
Solution	• Principle 002: Maximise Benefit to the Enterprise	✅	
Solution	• Principle 003: Designs will not include technologies that are legacy or in a contained state, nor introduce tech debt/regret spend.	✅	
Solution	• Principle 004: Protection of Intellectual Property	✅	
Solution	• Principle 005: Automation	✅	
Solution	• Principle 006: Designs will facilitate agility and adaptability	✅	
Solution	• Principle 007: Sustainability v2	✅	
Solution	• Principle 008: Compliance with Law	✅	
Solution	• Principle 009: Operational Log Aggregation and Monitoring	✅	
Business	• Principle 101: Requirements-Based Change	✅	
Business	• Principle 102: Business Continuity	✅	
Data	• Principle 201: Data Accuracy, Availability, and Quality Management	❎	

Data	• Principle 203: Enterprise Data Standardisation, Definitions and Model	✖	
Data	• Principle 204: Data is Classified and Protected	✖	
Data	• Principle 205: Data Replication is achieved with functional integration	✖	
Data	• Principle 206: Data Retention and Archiving	✖	
Data	• Principle 207: Master Data and Reference Data Management	✖	
Data	• Principle 208: Data for Reporting	✖	
Integration	• Principle 301: Event Driven Architecture	✔	
Integration	• Principle 302: Real-Time or Near Real-Time	✔	
Integration	• Principle 303: Batch Operations	✖	
Integration	• Principle 304: Loose Coupling	✔	
Integration	• Principle 305: Service Orientation	✔	
Integration	• Principle 306: Integration services shall be stateless and idempotent	✔	
Integration	• Principle 307: Data Exchange shall use a preferred method	✔	
Integration	• Principle 308: Third-party data exchange	✔	
Security & Privacy	• Principle 401: Collection and Storage of PI information	✖	
Security & Privacy	• Principle 402: Security Information and Event Management	✔	
Security & Privacy	• Principle 403: Designs meet the Security Control Requirements	✔	
Security & Privacy	• Principle 404: Authorisation uses Role and Attribute Based Access Control	✖	
Security & Privacy	• Principle 405: Data is encrypted in transit and at rest	✔	
Security & Privacy	• Principle 406: Externalise Identity and Access Management	✖	
Application	• Principle 501: Technical Orchestration	✖	
Application	• Principle 502: Focus on Differentiation	✔	
Application	• Principle 503: Re-use of Solutions and Platforms	✔	
Application	• Principle 504: User Centric Design	✔	
Infra & Ops	• Principle 601: Infrastructure deployment model hierarchy	✔	
Infra & Ops	• Principle 602: Public Cloud Infrastructure Provider	✔	
Infra & Ops	• Principle 603: IDP Technology Standards	✔	
Infra & Ops	• Principle 604: Cost Optimisation	✖	
Infra & Ops	• Principle 605: Enterprise Non Functional Requirements	✖	
Infra & Ops	• Principle 606: Migration Principles	✖	

Infra & Ops	• Principle 607: Technology Version Currency	❎	
Infra & Ops	• Principle 608: Disaster Recovery and Business Continuity v2.0 UNDEFINED	❎	
Infra & Ops	• Principle 609: Infrastructure as Code	✅	

References

PIA - Privacy Assesment Workflow

NFR: NFRs Template